

K. J. Somaiya School of Engineering

Department of Computer Engineering

Academic Year 2025–26

INTERNAL ASSESSMENT REPORT

Vulnerability Assessment using Nuclei

Network and Information Security — Course Code: 216U01C602

Submitted by

Aarya Patil — 16010123008

Bhoumish Grover — 16010123100

Yuvaan Shah — 16010123338

Faculty In-charge

Mr. Zaheed Shaikh

Demonstration Video Link:

 NIS_IA.mp4

1. Abstract

This report documents the implementation and analysis of Nuclei, a fast, open-source, template-based vulnerability scanner developed by ProjectDiscovery. The primary objective of this experiment was to gain hands-on experience with a professional-grade, community-driven security scanning tool and to understand how automated vulnerability detection operates across multiple network protocols simultaneously.

The tool was installed on macOS using the Homebrew package manager and configured with the official nuclei-templates library containing 9,904 templates. Scans were performed against scanme.nmap.org, a publicly available, legally scannable practice server maintained by the Nmap Project for security testing purposes. Multiple scan configurations were explored, including full template scans, severity-filtered scans, CVE-specific tag scans, misconfiguration scans, and JSON report generation.

The scan produced 31 findings across HTTP, SSH, and DNS protocols, including one officially registered CVE (CVE-2023-48795), multiple weak SSH cryptographic algorithm configurations, and eleven missing HTTP security response headers. The results demonstrate how automated tools can identify a broad attack surface across multiple protocol layers from a single command, and highlight the practical value of template-based detection in real-world security assessments.

2. Objectives

- To understand the principles of template-based vulnerability scanning and how it differs from traditional plugin-based approaches.
- To install, configure, and operate Nuclei v3.7.1 on macOS using Homebrew.
- To explore the core features of Nuclei including multi-protocol support, severity classification, tag-based filtering, rate control, and report generation.
- To perform multiple scan configurations against a legal practice target and interpret the findings at both a technical and risk level.
- To understand the structure of Nuclei YAML templates and how the detection logic is defined.
- To analyse discovered vulnerabilities, specifically CVE-2023-48795 (Terrapin Attack), weak SSH algorithms, and missing HTTP security headers.
- To understand the ethical and legal context of vulnerability scanning, including the importance of scanning only authorised targets.
- To appreciate the real-world applications of Nuclei in professional security workflows such as penetration testing, bug bounty hunting, and CI/CD pipeline integration.

3. Introduction

In the current digital landscape, security vulnerabilities are discovered and disclosed at an accelerating pace. Organisations face the challenge of identifying whether their systems are affected by newly disclosed CVEs within hours, not weeks. Traditional vulnerability scanners,

while comprehensive, often rely on vendor-maintained plugin systems that may lag behind public vulnerability disclosures and require expensive licensing.

Nuclei addresses this gap through a community-driven, template-based architecture. Developed by ProjectDiscovery and available at <https://github.com/projectdiscovery/nuclei>, it is a free, open-source tool written in Go that allows security researchers, penetration testers, and developers to run highly customisable vulnerability checks against any target. Each check is defined by a human-readable YAML template, and the community continuously contributes new templates, enabling near-real-time detection capability for newly disclosed vulnerabilities.

Unlike GUI-based tools, Nuclei is designed for the command line, making it scriptable, automatable, and suitable for integration into security pipelines. It supports simultaneous testing across multiple protocols, including HTTP/HTTPS, TCP/UDP, SSH, DNS, and SSL/TLS, providing a comprehensive view of a target's attack surface from a single invocation.

This experiment uses scanme.nmap.org as the target, a server explicitly made available by the Nmap Project for security scanning demonstrations. No unauthorized systems were targeted at any point during this experiment.

4. Features of the Tool

Nuclei provides a rich set of capabilities that distinguish it from conventional vulnerability scanners. The following features were explored and demonstrated during this experiment.

4.1 Template-Based Scanning

The most distinctive characteristic of Nuclei is its YAML template system. Every vulnerability check is defined by a standalone template file containing a unique identifier, severity classification, descriptive tags, the exact network request to construct, and a set of matchers that define what a vulnerable response looks like. This design means the tool's detection capability is entirely transparent and auditable — unlike compiled binary plugins. Templates can be inspected, modified, or written from scratch by any user. The official template library contains 9,904 templates at the time of this experiment (v10.4.0).

A sample template structure is shown below. This is the essential anatomy of any Nuclei template:

```
id: example-vulnerability

info:
  name: Example Vulnerability Check
  author: projectdiscovery
  severity: high
  tags: web, cve, exposure
```

```
requests:
  - method: GET
    path:
      - '{{BaseURL}}/vulnerable/endpoint'
    matchers:
      - type: word
        words:
          - 'vulnerable_string_in_response'
```

```
12332
bhoumishgrover@192 ~ % cat ~/nuclei-templates/http/misconfiguration/http-missing-security-headers.yaml
id: http-missing-security-headers
[
info:
  name: HTTP Missing Security Headers
  author: socketz,geeknik,G4L1T0,convisoappsec,kurohost,dawid-czarnecki,forgedhallpass,jub0bs,userdehghani,celbahraoui
  severity: info
  description: |
    This template searches for missing HTTP security headers. The impact of these missing headers can vary.
  metadata:
    max-request: 1
    tags: misconfig,headers,generic,vuln
http:
  - method: GET
    path:
      - "{{BaseURL}}"

    host-redirects: true
    max-redirects: 3

    matchers-condition: or
    matchers:
      - type: dsl
        name: strict-transport-security
        dsl:
          - '!regex('(?!i)strict-transport-security', header)"
          - "status_code != 301 && status_code != 302"
        condition: and

      - type: dsl
        name: content-security-policy
        dsl:
          - '!regex('(?!i)content-security-policy', header)"
          - "status_code != 301 && status_code != 302"
        condition: and

      - type: dsl
        name: permissions-policy
        dsl:
          - '!regex('(?!i)permissions-policy', header)"
          - "status_code != 301 && status_code != 302"
        condition: and

      - type: dsl
        name: x-frame-options
        dsl:
          - '!regex('(?!i)x-frame-options', header)"
          - "status_code != 301 && status_code != 302"
        condition: and

      - type: dsl
        name: x-content-type-options
        dsl:
          - '!regex('(?!i)x-content-type-options', header)"
          - "status_code != 301 && status_code != 302"
        condition: and

      - type: dsl
        name: x-permitted-cross-domain-policies
        dsl:
          - '!regex('(?!i)x-permitted-cross-domain-policies', header)"
          - "status_code != 301 && status_code != 302"
        condition: and

      - type: dsl
        name: referrer-policy
        dsl:
          - '!regex('(?!i)referrer-policy', header)"
```

4.2 Multi-Protocol Support

Nuclei is not limited to web application scanning. In a single scan invocation, it simultaneously executes templates across multiple protocol runners: HTTP/HTTPS for web applications and APIs, TCP/UDP for raw network-level checks, DNS for record enumeration and misconfiguration detection, JavaScript-based checks for complex services like SSH and SNMP, and SSL/TLS for certificate and cipher suite analysis. This was directly evidenced in the scanme.nmap.org scan, which simultaneously discovered HTTP header issues, SSH cryptographic vulnerabilities on port 22, DNS records, and server fingerprinting information.

```
bhoushigrover@192 ~ % nuclei -u http://scanme.nmap.org -pt http

  _____
 /  _  _  _  \
|  _ \| | | | | | |
| |_) | |_| | |
|  _ \| | | | |
|_| \_|_|_|_|_|
v3.7.1

projectdiscovery.io

[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: v10.4.0 (latest)
[INF] New templates added in latest release: 94
[INF] Templates loaded for current scan: 9468
[WRN] Loading 16 unsigned templates for scan. Use with caution.
[INF] Executing 9452 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 2206 (Reduced 2886 Requests)
[INF] Using Interactsh Server: oast.pro
[apache-mod-negotiation-listing:exposed_files] [http] [low] http://scanme.nmap.org/index ["index.html"] [path="/index"]
[waif-detect:apachegeneric] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:content-security-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:permissions-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:cross-origin-embedder-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:cross-origin-resource-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:missing-content-type] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:strict-transport-security] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:x-frame-options] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:x-content-type-options] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:referrer-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:clear-site-data] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:cross-origin-opener-policy] [http] [info] http://scanme.nmap.org
[form-detection] [http] [info] http://scanme.nmap.org
[INF] Skipped scanme.nmap.org:4040 from target list as found unresponsive permanently: cause="port closed or filtered" address=scanme.nmap.org:4040 chain="connection refused; |
got err while executing http://scanme.nmap.org:4040/jobs/"
[INF] Skipped scanme.nmap.org:5814 from target list as found unresponsive permanently: Get "https://scanme.nmap.org:5814/autopass": cause="port closed or filtered" address=scanme.nmap.org:5814 chain="connection refused"
[apache-detect] [http] [info] http://scanme.nmap.org ["Apache/2.4.7 (Ubuntu)"]
[options-method] [http] [info] http://scanme.nmap.org ["GET,HEAD,POST,OPTIONS"]
[INF] Scan completed in 4m. 17 matches found.
```

```
bhoushigrover@192 ~ % nuclei -u scanme.nmap.org -pt tcp
```

```
  _____
 /  _  _  _  \
|  _ \| | | | | | |
| |_) | |_| | |
|  _ \| | | | |
|_| \_|_|_|_|_|
v3.7.1

projectdiscovery.io

[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: v10.4.0 (latest)
[INF] New templates added in latest release: 94
[INF] Templates loaded for current scan: 276
[INF] Executing 275 signed templates from projectdiscovery/nuclei-templates
[WRN] Loading 1 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 1
[openssh-detect] [tcp] [info] scanme.nmap.org:22 ["SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13"]
[INF] Scan completed in 12.487038375s. 1 matches found.
bhoushigrover@192 ~ % nuclei -u http://scanme.nmap.org -etags ssl
```

4.3 Severity Classification

All findings are automatically classified into five severity levels based on the metadata defined in each template: Critical, High, Medium, Low, and Informational. This classification enables security teams to prioritise remediation efforts systematically, addressing the most impactful vulnerabilities first. The severity can be filtered at scan time using the `-severity` flag, allowing analysts to focus only on findings that require immediate attention and reduce noise in the output.

```

12352
bhumishgrover@192 ~ % nuclei -u http://scanme.nmap.org -severity medium,high,critical

nuclei
v3.7.1
projectdiscovery.io

[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: v10.4.0 (latest)
[INF] New templates added in latest release: 94
[INF] Templates loaded for current scan: 5931
[INF] Executing 5930 signed templates from projectdiscovery/nuclei-templates
[WARN] Loading 1 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 349 (Reduced 296 Requests)
[INF] Using Interactsh Server: oast.live
[ssh-weak-algo-supported] [javascript] [medium] scanme.nmap.org:22
[CVE-2023-48795] [javascript] [medium] scanme.nmap.org:22 ["Vulnerable to Terrapin"]
[INF] Skipped scanme.nmap.org:4040 from target list as found unresponsive permanently: cause="port closed or filtered" address=scanme.nmap.org:4040 chain="connection refused; got err while executing h
https://scanme.nmap.org:4040/jobs/?\ "><script>alert(document.domain)</script>"
[INF] Scan completed in 3m. 2 matches found.

```

4.4 Tag-Based Filtering

The template library is organised using a rich tagging system. Common tags include cve (officially registered CVE vulnerabilities), misconfig (server and application misconfigurations), exposure (accidentally exposed panels, files, or credentials), network (network-level service checks), ssl (TLS/SSL certificate checks), and default-login (default credential detection). Using the `-tags` flag, a scan can be restricted to a specific category, making it far more efficient when the analyst already knows what class of vulnerability they are looking for.

```

[INF] Scan completed in 2m. 2 matches found.
bhumishgrover@192 ~ % nuclei -u http://scanme.nmap.org -tags cve

nuclei
v3.7.1
projectdiscovery.io

[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: v10.4.0 (latest)
[INF] New templates added in latest release: 94
[INF] Templates loaded for current scan: 3937
[INF] Executing 3937 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 39 (Reduced 29 Requests)
[INF] Using Interactsh Server: oast.site
[CVE-2023-48795] [javascript] [medium] scanme.nmap.org:22 ["Vulnerable to Terrapin"]
[INF] Scan completed in 1m. 1 matches found.

```

```
bhoushishgrover@192 ~ % nuclei -u http://scanme.nmap.org -tags misconfig

      _____
     /  _  _  _  \
    /  _  _  _  \
   /  _  _  _  \
  /  _  _  _  \
 /  _  _  _  \
/  _  _  _  \
\  _  _  _  /
 \  _  _  _ /
  \  _  _  /
   \  _  /
    \  _/
     \_/_

v3.7.1

projectdiscovery.io

[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: v10.4.0 (latest)
[INF] New templates added in latest release: 94
[INF] Templates loaded for current scan: 927
[INF] Executing 927 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 279 (Reduced 248 Requests)
[apache-mod-negotiation-listing:exposed_files] [http] [low] http://scanme.nmap.org/index ["index.html"] [path="/index.html"]
[INF] Using Interactsh Server: oast.pro
[ssh-sha1-hmac-algo] [javascript] [info] scanme.nmap.org:22
[ssh-weak-mac-algo] [javascript] [low] scanme.nmap.org:22
[ssh-weakkey-exchange-algo] [javascript] [low] scanme.nmap.org:22
[ssh-diffie-hellman-logjam] [javascript] [low] scanme.nmap.org:22
[ssh-weak-algo-supported] [javascript] [medium] scanme.nmap.org:22
[ssh-cbc-mode-ciphers] [javascript] [low] scanme.nmap.org:22
[INF] Skipped scanme.nmap.org:5814 from target list as found unresponsive permanently: Get "https://scanme.nmap.org:5814":
nme.nmap.org:5814 chain="connection refused"
[[http-missing-security-headers:cross-origin-resource-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:cross-origin-resource-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:strict-transport-security] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:referrer-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:cross-origin-embedder-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:cross-origin-opener-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:content-security-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:permissions-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:x-frame-options] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:x-content-type-options] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:clear-site-data] [http] [info] http://scanme.nmap.org
[INF] Scan completed in 59.200793084s. 19 matches found.
```

4.5 Rate Limiting and Concurrency Control

By default, Nuclei executes templates aggressively to maximise speed. In professional environments, this can trigger intrusion detection systems or destabilise the target. The `-rate-limit` flag controls the maximum number of requests per second, and the `-c` flag controls the number of templates executed concurrently. These controls are essential for responsible scanning in real engagements and demonstrate an understanding of operational security during assessments.

```
bhoumishgrover@192 ~ % nuclei -u http://scanme.nmap.org --rate-limit 50 --severity medium,low
```

v3.7.1
projectdiscovery.io

```
[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: v10.4.0 (latest)
[INF] New templates added in latest release: 94
[INF] Templates loaded for current scan: 2509
[WRN] Loading 1 unsigned templates for scan. Use with caution.
[INF] Executing 2508 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 149 (Reduced 137 Requests)
[INF] Using Interactsh Server: oast.me
[apache-mod-negotiation-listing:exposed_files] [http] [low] http://scanme.nmap.org/index ["index.html"] [path="/index"]
[ssh-cbc-mode-ciphers] [javascript] [low] scanme.nmap.org:22
[ssh-diffie-hellman-logjam] [javascript] [low] scanme.nmap.org:22
[ssh-weakkey-exchange-algo] [javascript] [low] scanme.nmap.org:22
[CVE-2023-48795] [javascript] [medium] scanme.nmap.org:22 ["Vulnerable to Terrapin"]
[ssh-weak-algo-supported] [javascript] [medium] scanme.nmap.org:22
[ssh-weak-mac-algo] [javascript] [low] scanme.nmap.org:22
[INF] Skipped scanme.nmap.org:4040 from target list as found unresponsive permanently: cause="port closed or filtered" ad
got err while executing https://scanme.nmap.org:4040/jobs/?"><script>alert(document.domain)</script>"
[INF] Scan completed in 1m. 7 matches found.
```

```

bhoumishgrover@192 ~ % nuclei -u http://scanme.nmap.org -c 10 -severity info

      ____  _
     / ___/  /
    /  /  /  /
   /  /  /  /
  /  /  /  /
 /  /  /  /
/  /  /  /
v3.7.1

projectdiscovery.io

[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: v10.4.0 (latest)
[INF] New templates added in latest release: 94
[INF] Templates loaded for current scan: 3481
[INF] Executing 3466 signed templates from projectdiscovery/nuclei-templates
[WRN] Loading 15 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 1753 (Reduced 1682 Requests)
[INF] Using Interactsh Server: oast.me
[waf-detect:apachegeneric] [http] [info] http://scanme.nmap.org
[ssh-auth-methods] [javascript] [info] scanme.nmap.org:22 [{"publickey","password"}]
[ssh-password-auth] [javascript] [info] scanme.nmap.org:22
[ssh-server-enumeration] [javascript] [info] scanme.nmap.org:22 ["SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13"]
[ssh-sha1-hmac-algo] [javascript] [info] scanme.nmap.org:22
[snmpv3-detect] [javascript] [info] scanme.nmap.org:161 ["Enterprise: unknown"]
[openssh-detect] [tcp] [info] scanme.nmap.org:22 ["SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13"]
[INF] Skipped scanme.nmap.org:5814 from target list as found unresponsive permanently: Get "https://scanme.nmap.org:5814 chain="connection refused"
[options-method] [http] [info] http://scanme.nmap.org ["GET,HEAD,POST,OPTIONS"]
[apache-detect] [http] [info] http://scanme.nmap.org ["Apache/2.4.7 (Ubuntu)"]
[http-missing-security-headers:content-security-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:referrer-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:cross-origin-embedder-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:cross-origin-resource-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:missing-content-type] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:permissions-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:x-frame-options] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:x-content-type-options] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:clear-site-data] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:cross-origin-opener-policy] [http] [info] http://scanme.nmap.org
[http-missing-security-headers:strict-transport-security] [http] [info] http://scanme.nmap.org
[form-detection] [http] [info] http://scanme.nmap.org
[aaaa-fingerprint] [dns] [info] scanme.nmap.org ["2600:3c01::f03c:91ff:fe18:bb2f"]
[caa-fingerprint] [dns] [info] scanme.nmap.org
[INF] Scan completed in 2m. 24 matches found.

```

4.6 Output and Report Generation

Findings can be saved in two formats. Plain text output (-o report.txt) is human-readable and suitable for documentation. JSON Lines output (-jsonl -o report.json) produces structured, machine-parseable records, one per finding, containing the template ID, protocol, severity, matched target, evidence extracted from the response, and timestamp. The JSON format is used in professional security pipelines and CI/CD integrations where downstream tools need to process findings programmatically.

```
[bhoumishgrover@192 ~ % nuclei -u http://scanme.nmap.org -jsonl -o nuclei-report.json
```

[illegible]

```
[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: v10.4.0 (latest)
[INF] New templates added in latest release: 94
[INF] Templates loaded for current scan: 9904
[INF] Executing 9887 signed templates from projectdiscovery/nuclei-templates
[WRN] Loading 17 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 2255 (Reduced 2130 Requests)
[INF] Using Interactsh Server: oast.site
{"template":"http/misconfiguration/apache/apache-mod-negotiation-listing.yaml","template-url":"https://cloud.projectdiscovery.io/public/apache-mod-negotiation-listing","template-id":"apache-mod-negotiation-listing","template-path":"/Users/bhoomishgrover/nuclei-templates/http/misconfiguration/apache/apache-mod-negotiation-listing","info":{"name":"Apache mod_negotiation - Pseudo Directory Listing","author":["0x_akoko"],"tags":["apache","misconfig"],"exposure":"mod_negotiation and MultiViews enabled, exposing a pseudo directory listing when invalid Accept headers are sent to user-agent","cve-id":["CVE-2020-13936"],"cvss-metrics":"CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N"},"url":"https://cwe.mitre.org/data/definitions/538","max-request":5,"classification":{"cve-id":null,"cwe-id":["cwe-538"],"cvss-metrics":"CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N"},"type":{"http":{"host":"scanme.nmap.org","port":"80","scheme":"http","url":"http://scanme.nmap.org","path":"/index.html"},"https":{"host":"scanme.nmap.org","port":"443","scheme":"https","url":"https://scanme.nmap.org","path":"/index.html"},"ftp":{"host":"scanme.nmap.org","port":"21","scheme":"ftp","url":"ftp://scanme.nmap.org","path":"/index.html"},"ssh":{"host":"scanme.nmap.org","port":"22","scheme":"ssh","url":"ssh://scanme.nmap.org","path":"/index.html"},"telnet":{"host":"scanme.nmap.org","port":"23","scheme":"telnet","url":"telnet://scanme.nmap.org","path":"/index.html"},"irc":{"host":"scanme.nmap.org","port":"6666","scheme":"irc","url":"irc://scanme.nmap.org","path":"/index.html"},"ldap":{"host":"scanme.nmap.org","port":"389","scheme":"ldap","url":"ldap://scanme.nmap.org","path":"/index.html"},"rdp":{"host":"scanme.nmap.org","port":"3389","scheme":"rdp","url":"rdp://scanme.nmap.org","path":"/index.html"},"vnc":{"host":"scanme.nmap.org","port":"5901","scheme":"vnc","url":"vnc://scanme.nmap.org","path":"/index.html"},"xmpp":{"host":"scanme.nmap.org","port":"5222","scheme":"xmpp","url":"xmpp://scanme.nmap.org","path":"/index.html"},"smtp":{"host":"scanme.nmap.org","port":"25","scheme":"smtp","url":"smtp://scanme.nmap.org","path":"/index.html"},"pop3":{"host":"scanme.nmap.org","port":"110","scheme":"pop3","url":"pop3://scanme.nmap.org","path":"/index.html"},"imap":{"host":"scanme.nmap.org","port":"143","scheme":"imap","url":"imap://scanme.nmap.org","path":"/index.html"},"nntp":{"host":"scanme.nmap.org","port":"119","scheme":"nntp","url":"nntp://scanme.nmap.org","path":"/index.html"},"irc666":{"host":"scanme.nmap.org","port":"6666","scheme":"irc666","url":"irc666://scanme.nmap.org","path":"/index.html"},"irc667":{"host":"scanme.nmap.org","port":"6667","scheme":"irc667","url":"irc667://scanme.nmap.org","path":"/index.html"},"irc669":{"host":"scanme.nmap.org","port":"6669","scheme":"irc669","url":"irc669://scanme.nmap.org","path":"/index.html"},"irc670":{"host":"scanme.nmap.org","port":"6700","scheme":"irc670","url":"irc670://scanme.nmap.org","path":"/index.html"},"irc671":{"host":"scanme.nmap.org","port":"6711","scheme":"irc671","url":"irc671://scanme.nmap.org","path":"/index.html"},"irc672":{"host":"scanme.nmap.org","port":"6722","scheme":"irc672","url":"irc672://scanme.nmap.org","path":"/index.html"},"irc673":{"host":"scanme.nmap.org","port":"6733","scheme":"irc673","url":"irc673://scanme.nmap.org","path":"/index.html"},"irc674":{"host":"scanme.nmap.org","port":"6744","scheme":"irc674","url":"irc674://scanme.nmap.org","path":"/index.html"},"irc675":{"host":"scanme.nmap.org","port":"6755","scheme":"irc675","url":"irc675://scanme.nmap.org","path":"/index.html"},"irc676":{"host":"scanme.nmap.org","port":"6766","scheme":"irc676","url":"irc676://scanme.nmap.org","path":"/index.html"},"irc677":{"host":"scanme.nmap.org","port":"6777","scheme":"irc677","url":"irc677://scanme.nmap.org","path":"/index.html"},"irc678":{"host":"scanme.nmap.org","port":"6788","scheme":"irc678","url":"irc678://scanme.nmap.org","path":"/index.html"},"irc679":{"host":"scanme.nmap.org","port":"6799","scheme":"irc679","url":"irc679://scanme.nmap.org","path":"/index.html"},"irc680":{"host":"scanme.nmap.org","port":"6800","scheme":"irc680","url":"irc680://scanme.nmap.org","path":"/index.html"},"irc681":{"host":"scanme.nmap.org","port":"6811","scheme":"irc681","url":"irc681://scanme.nmap.org","path":"/index.html"},"irc682":{"host":"scanme.nmap.org","port":"6822","scheme":"irc682","url":"irc682://scanme.nmap.org","path":"/index.html"},"irc683":{"host":"scanme.nmap.org","port":"6833","scheme":"irc683","url":"irc683://scanme.nmap.org","path":"/index.html"},"irc684":{"host":"scanme.nmap.org","port":"6844","scheme":"irc684","url":"irc684://scanme.nmap.org","path":"/index.html"},"irc685":{"host":"scanme.nmap.org","port":"6855","scheme":"irc685","url":"irc685://scanme.nmap.org","path":"/index.html"},"irc686":{"host":"scanme.nmap.org","port":"6866","scheme":"irc686","url":"irc686://scanme.nmap.org","path":"/index.html"},"irc687":{"host":"scanme.nmap.org","port":"6877","scheme":"irc687","url":"irc687://scanme.nmap.org","path":"/index.html"},"irc688":{"host":"scanme.nmap.org","port":"6888","scheme":"irc688","url":"irc688://scanme.nmap.org","path":"/index.html"},"irc689":{"host":"scanme.nmap.org","port":"6899","scheme":"irc689","url":"irc689://scanme.nmap.org","path":"/index.html"},"irc690":{"host":"scanme.nmap.org","port":"6900","scheme":"irc690","url":"irc690://scanme.nmap.org","path":"/index.html"},"irc691":{"host":"scanme.nmap.org","port":"6911","scheme":"irc691","url":"irc691://scanme.nmap.org","path":"/index.html"},"irc692":{"host":"scanme.nmap.org","port":"6922","scheme":"irc692","url":"irc692://scanme.nmap.org","path":"/index.html"},"irc693":{"host":"scanme.nmap.org","port":"6933","scheme":"irc693","url":"irc693://scanme.nmap.org","path":"/index.html"},"irc694":{"host":"scanme.nmap.org","port":"6944","scheme":"irc694","url":"irc694://scanme.nmap.org","path":"/index.html"},"irc695":{"host":"scanme.nmap.org","port":"6955","scheme":"irc695","url":"irc695://scanme.nmap.org","path":"/index.html"},"irc696":{"host":"scanme.nmap.org","port":"6966","scheme":"irc696","url":"irc696://scanme.nmap.org","path":"/index.html"},"irc697":{"host":"scanme.nmap.org","port":"6977","scheme":"irc697","url":"irc697://scanme.nmap.org","path":"/index.html"},"irc698":{"host":"scanme.nmap.org","port":"6988","scheme":"irc698","url":"irc698://scanme.nmap.org","path":"/index.html"},"irc699":{"host":"scanme.nmap.org","port":"6999","scheme":"irc699","url":"irc699://scanme.nmap.org","path":"/index.html"},"irc700":{"host":"scanme.nmap.org","port":"7000","scheme":"irc700","url":"irc700://scanme.nmap.org","path":"/index.html"},"irc701":{"host":"scanme.nmap.org","port":"7001","scheme":"irc701","url":"irc701://scanme.nmap.org","path":"/index.html"},"irc702":{"host":"scanme.nmap.org","port":"7002","scheme":"irc702","url":"irc702://scanme.nmap.org","path":"/index.html"},"irc703":{"host":"scanme.nmap.org","port":"7003","scheme":"irc703","url":"irc703://scanme.nmap.org","path":"/index.html"},"irc704":{"host":"scanme.nmap.org","port":"7004","scheme":"irc704","url":"irc704://scanme.nmap.org","path":"/index.html"},"irc705":{"host":"scanme.nmap.org","port":"7005","scheme":"irc705","url":"irc705://scanme.nmap.org","path":"/index.html"},"irc706":{"host":"scanme.nmap.org","port":"7006","scheme":"irc706","url":"irc706://scanme.nmap.org","path":"/index.html"},"irc707":{"host":"scanme.nmap.org","port":"7007","scheme":"irc707","url":"irc707://scanme.nmap.org","path":"/index.html"},"irc708":{"host":"scanme.nmap.org","port":"7008","scheme":"irc708","url":"irc708://scanme.nmap.org","path":"/index.html"},"irc709":{"host":"scanme.nmap.org","port":"7009","scheme":"irc709","url":"irc709://scanme.nmap.org","path":"/index.html"},"irc710":{"host":"scanme.nmap.org","port":"7010","scheme":"irc710","url":"irc710://scanme.nmap.org","path":"/index.html"},"irc711":{"host":"scanme.nmap.org","port":"7011","scheme":"irc711","url":"irc711://scanme.nmap.org","path":"/index.html"},"irc712":{"host":"scanme.nmap.org","port":"7012","scheme":"irc712","url":"irc712://scanme.nmap.org","path":"/index.html"},"irc713":{"host":"scanme.nmap.org","port":"7013","scheme":"irc713","url":"irc713://scanme.nmap.org","path":"/index.html"},"irc714":{"host":"scanme.nmap.org","port":"7014","scheme":"irc714","url":"irc714://scanme.nmap.org","path":"/index.html"},"irc715":{"host":"scanme.nmap.org","port":"7015","scheme":"irc715","url":"irc715://scanme.nmap.org","path":"/index.html"},"irc716":{"host":"scanme.nmap.org","port":"7016","scheme":"irc716","url":"irc716://scanme.nmap.org","path":"/index.html"},"irc717":{"host":"scanme.nmap.org","port":"7017","scheme":"irc717","url":"irc717://scanme.nmap.org","path":"/index.html"},"irc718":{"host":"scanme.nmap.org","port":"7018","scheme":"irc718","url":"irc718://scanme.nmap.org","path":"/index.html"},"irc719":{"host":"scanme.nmap.org","port":"7019","scheme":"irc719","url":"irc719://scanme.nmap.org","path":"/index.html"},"irc720":{"host":"scanme.nmap.org","port":"7020","scheme":"irc720","url":"irc720://scanme.nmap.org","path":"/index.html"},"irc721":{"host":"scanme.nmap.org","port":"7021","scheme":"irc721","url":"irc721://scanme.nmap.org","path":"/index.html"},"irc722":{"host":"scanme.nmap.org","port":"7022","scheme":"irc722","url":"irc722://scanme.nmap.org","path":"/index.html"},"irc723":{"host":"scanme.nmap.org","port":"7023","scheme":"irc723","url":"irc723://scanme.nmap.org","path":"/index.html"},"irc724":{"host":"scanme.nmap.org","port":"7024","scheme":"irc724","url":"irc724://scanme.nmap.org","path":"/index.html"},"irc725":{"host":"scanme.nmap.org","port":"7025","scheme":"irc725","url":"irc725://scanme.nmap.org","path":"/index.html"},"irc726":{"host":"scanme.nmap.org","port":"7026","scheme":"irc726","url":"irc726://scanme.nmap.org","path":"/index.html"},"irc727":{"host":"scanme.nmap.org","port":"7027","scheme":"irc727","url":"irc727://scanme.nmap.org","path":"/index.html"},"irc728":{"host":"scanme.nmap.org","port":"7028","scheme":"irc728","url":"irc728://scanme.nmap.org","path":"/index.html"},"irc729":{"host":"scanme.nmap.org","port":"7029","scheme":"irc729","url":"irc729://scanme.nmap.org","path":"/index.html"},"irc730":{"host":"scanme.nmap.org","port":"7030","scheme":"irc730","url":"irc730://scanme.nmap.org","path":"/index.html"},"irc731":{"host":"scanme.nmap.org","port":"7031","scheme":"irc731","url":"irc731://scanme.nmap.org","path":"/index.html"},"irc732":{"host":"scanme.nmap.org","port":"7032","scheme":"irc732","url":"irc732://scanme.nmap.org","path":"/index.html"},"irc733":{"host":"scanme.nmap.org","port":"7033","scheme":"irc733","url":"irc733://scanme.nmap.org","path":"/index.html"},"irc734":{"host":"scanme.nmap.org","port":"7034","scheme":"irc734","url":"irc734://scanme.nmap.org","path":"/index.html"},"irc735":{"host":"scanme.nmap.org","port":"7035","scheme":"irc735","url":"irc735://scanme.nmap.org","path":"/index.html"},"irc736":{"host":"scanme.nmap.org","port":"7036","scheme":"irc736","url":"irc736://scanme.nmap.org","path":"/index.html"},"irc737":{"host":"scanme.nmap.org","port":"7037","scheme":"irc737","url":"
```



```
# Output:
[INF] Nuclei Engine Version: v3.7.1
[INF] Nuclei Config Directory: /Users/<user>/Library/Application Support/nuclei
[INF] Nuclei Cache Directory: /Users/<user>/Library/Caches/nuclei
```

3. The community template library was installed and updated:

```
nuclei -update-templates
```

Output:

```
[INF] nuclei-templates are not installed, installing...
[INF] Successfully installed nuclei-templates at /Users/<user>/nuclei-templates
[INF] No new updates found for nuclei templates
```

No additional software, local servers, GUI applications, or database setup was required. Nuclei runs entirely from the command line and contacts targets over the network directly.

Screenshots:

```

lbhoushgrover@192 ~ % brew install nuclei
==> Auto-updating Homebrew...
Adjust how often this is run with `HOMEBREW_AUTO_UPDATE_SECS` or disable with
`HOMEBREW_NO_AUTO_UPDATE=1`. Hide these hints with `HOMEBREW_NO_ENV_HINTS=1` (see `man brew`).
==> Downloading https://ghcr.io/v2/homebrew/core/portable-ruby/blobs/sha256:cef6f881f516d2cddb0a5bfc7e20318da8b047cf2674ee27c5d
4858d3ecd6430
##### 100.0%
==> Pouring portable-ruby-4.0.1.arm64_big_sur.bottle.tar.gz
==> Auto-updated Homebrew!
Updated 3 taps (mongodb/brew, homebrew/core and homebrew/cask).
==> New Formulae
actions-up: Tool to update GitHub Actions to latest versions with SHA pinning
aoe: Terminal session manager for AI coding agents
apache-arrow-adbc: Cross-language, Arrow-native database access
apache-serf: High-performance asynchronous HTTP client library

```

```
==> Fetching downloads for: nuclei
✓ Bottle Manifest nuclei (3.7.1)                               Downloaded      7.4KB/   7.4KB
✓ Bottle nuclei (3.7.1)                                         Downloaded    37.6MB/  37.6MB
==> Pouring nuclei--3.7.1.arm64_tahoe.bottle.tar.gz
🍺  /opt/homebrew/Cellar/nuclei/3.7.1: 6 files, 118.8MB
==> Running `brew cleanup nuclei`...
Disable this behaviour by setting `HOMEBREW_NO_INSTALL_CLEANUP=1`.
Hide these hints with `HOMEBREW_NO_ENV_HINTS=1` (see `man brew`).
```

```
bhoushishgrover@192 ~ % nuclei -version
[INF] Nuclei Engine Version: v3.7.1
[INF] Nuclei Config Directory: /Users/bhoushishgrover/Library/Application Support/nuclei
[INF] Nuclei Cache Directory: /Users/bhoushishgrover/Library/Caches/nuclei
[INF] PDCP Directory: /Users/bhoushishgrover/.pdc
bhoushishgrover@192 ~ % nuclei -update-templates
flag provided but not defined: -update-templates
bhoushishgrover@192 ~ % nuclei -update-templates
```

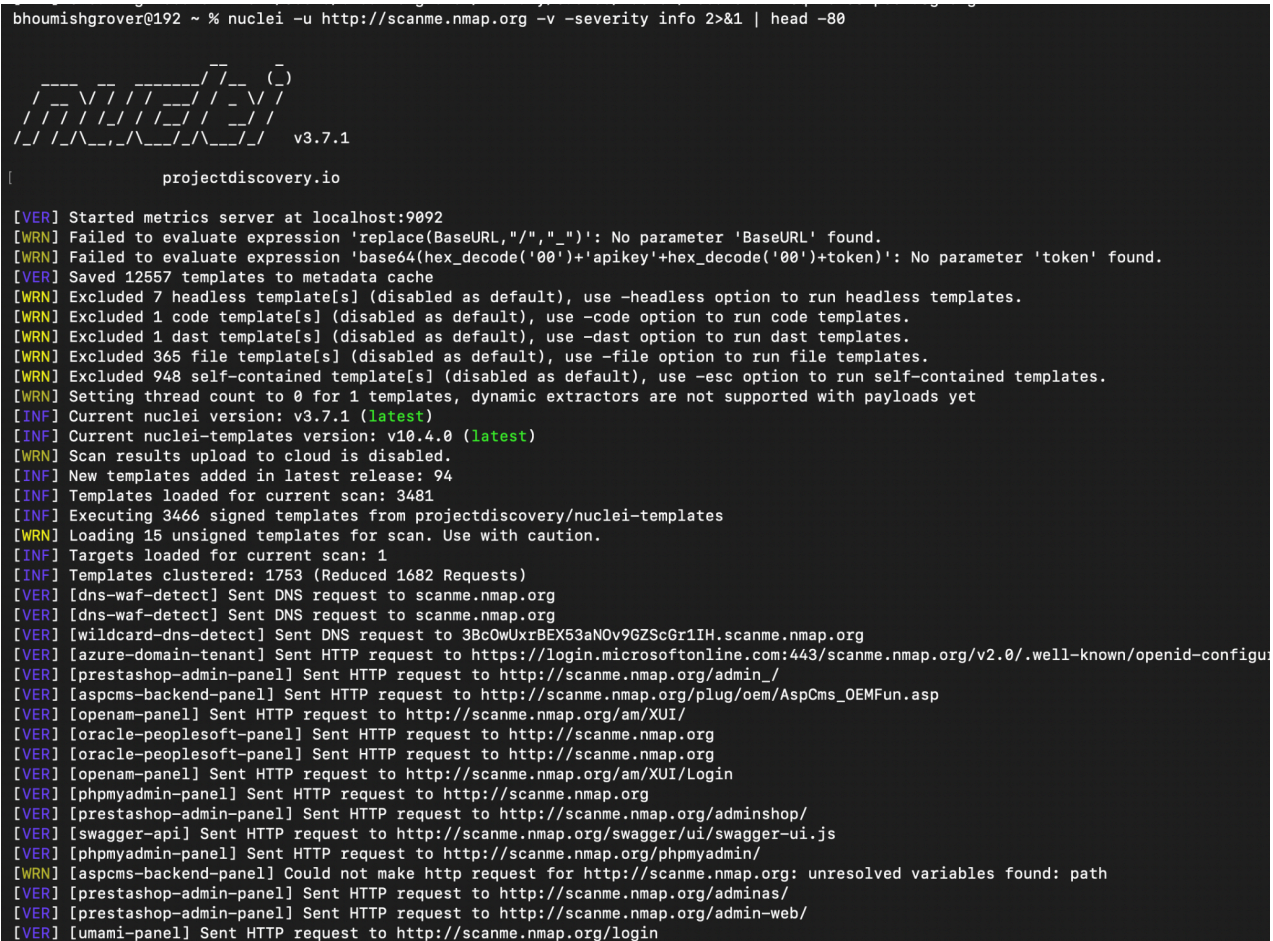
[illegible]

projectdiscovery.io

5.3 Target Selection

The target chosen for all scans was scanme.nmap.org, a server maintained by the Nmap Security Scanner Project for the specific purpose of allowing security researchers and students to legally practice scanning techniques. The server is intentionally configured with detectable services and known vulnerabilities. Scanning any other target without explicit written authorisation is illegal and unethical. All activity in this experiment was confined to this designated practice server.

```
bhoushishgrover@192 ~ % nuclei -u http://scanme.nmap.org -v -severity info 2>&1 | head -80
```



```

projectdiscovery.io

[VER] Started metrics server at localhost:9092
[WRN] Failed to evaluate expression 'replace(BaseURL,"/","_")': No parameter 'BaseURL' found.
[WRN] Failed to evaluate expression 'base64(hex_decode('00'))+apikey'+hex_decode('00')+token)': No parameter 'token' found.
[VER] Saved 12557 templates to metadata cache
[WRN] Excluded 7 headless template[s] (disabled as default), use -headless option to run headless templates.
[WRN] Excluded 1 code template[s] (disabled as default), use -code option to run code templates.
[WRN] Excluded 1 dast template[s] (disabled as default), use -dast option to run dast templates.
[WRN] Excluded 365 file template[s] (disabled as default), use -file option to run file templates.
[WRN] Excluded 948 self-contained template[s] (disabled as default), use -esc option to run self-contained templates.
[WRN] Setting thread count to 0 for 1 templates, dynamic extractors are not supported with payloads yet
[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: v10.4.0 (latest)
[WRN] Scan results upload to cloud is disabled.
[INF] New templates added in latest release: 94
[INF] Templates loaded for current scan: 3481
[INF] Executing 3466 signed templates from projectdiscovery/nuclei-templates
[WRN] Loading 15 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 1753 (Reduced 1682 Requests)
[VER] [dns-waf-detect] Sent DNS request to scanme.nmap.org
[VER] [dns-waf-detect] Sent DNS request to scanme.nmap.org
[VER] [wildcard-dns-detect] Sent DNS request to 3Bc0wUxrBEX53aNOv9GZScGr1IH.scanme.nmap.org
[VER] [azure-domain-tenant] Sent HTTP request to https://login.microsoftonline.com:443/scanme.nmap.org/v2.0/.well-known/openid-configu
[VER] [prestashop-admin-panel] Sent HTTP request to http://scanme.nmap.org/admin_/
[VER] [aspcms-backend-panel] Sent HTTP request to http://scanme.nmap.org/plugin/oem/AspCms_OEMFun.asp
[VER] [openam-panel] Sent HTTP request to http://scanme.nmap.org/am/XUI/
[VER] [oracle-peoplesoft-panel] Sent HTTP request to http://scanme.nmap.org
[VER] [oracle-peoplesoft-panel] Sent HTTP request to http://scanme.nmap.org
[VER] [openam-panel] Sent HTTP request to http://scanme.nmap.org/am/XUI/Login
[VER] [phpmyadmin-panel] Sent HTTP request to http://scanme.nmap.org
[VER] [prestashop-admin-panel] Sent HTTP request to http://scanme.nmap.org/adminshop/
[VER] [swagger-api] Sent HTTP request to http://scanme.nmap.org/swagger/ui/swagger-ui.js
[VER] [phpmyadmin-panel] Sent HTTP request to http://scanme.nmap.org/phpmyadmin/
[WRN] [aspcms-backend-panel] Could not make http request for http://scanme.nmap.org: unresolved variables found: path
[VER] [prestashop-admin-panel] Sent HTTP request to http://scanme.nmap.org/adminas/
[VER] [prestashop-admin-panel] Sent HTTP request to http://scanme.nmap.org/admin-web/
[VER] [umami-panel] Sent HTTP request to http://scanme.nmap.org/login

```

6. Experimentation and Results

Six distinct scan configurations were executed against scanme.nmap.org to demonstrate the breadth of Nuclei's capabilities. Each scan was run sequentially and its output was observed and recorded.

6.1 Scan 1 — Basic Full Scan

The first scan executed all available templates against the target with no filters applied. This provides the broadest possible view of the target's vulnerability surface.

```
nuclei -u http://scanme.nmap.org
```

Key output metrics:

- Templates loaded: 9,904
- Templates clustered: 2,255 (reduced total requests by 2,130 through deduplication)
- Scan duration: 4 minutes
- Total findings: 31 matches across HTTP, SSH, and DNS protocols

The clustering optimisation is worth noting: Nuclei identified that multiple templates could reuse the same underlying HTTP request, reducing 9,904 template executions to approximately 7,774 actual network requests. This is a core efficiency feature of the engine.

6.2 Scan 2 — Severity-Filtered Scan

This scan filtered results to show only Medium and Low severity findings, removing informational noise to focus on actionable vulnerabilities.

```
nuclei -u http://scanme.nmap.org -severity medium,low
```

This command is particularly valuable in real-world scenarios where a full scan produces hundreds of informational findings. By filtering to medium and low severity, the analyst sees only results that represent genuine security risks requiring remediation decisions.

6.3 Scan 3 — CVE Tag Scan

This scan restricted execution to only those templates tagged with cve, targeting only officially registered and documented vulnerabilities.

```
nuclei -u http://scanme.nmap.org -tags cve
```

This scan confirmed the presence of CVE-2023-48795 (the Terrapin Attack) on the SSH service running on port 22. CVE-specific scans are especially useful for rapid impact assessment after a new vulnerability disclosure, allowing teams to determine exposure within minutes.

6.4 Scan 4 — Misconfiguration Tag Scan

This scan targeted only misconfiguration templates, which check for server and application settings that deviate from security best practices.

```
nuclei -u http://scanme.nmap.org -tags misconfig
```

Eleven missing HTTP security response headers were identified, including Content-Security-Policy, X-Frame-Options, Strict-Transport-Security, Permissions-Policy, and Cross-Origin-Opener-Policy. These headers, while not exploitable on their own, significantly increase the risk of secondary attacks such as cross-site scripting and clickjacking.

6.5 Scan 5 — JSON Report Generation

This scan saved the full output to a structured JSON Lines file for documentation and further analysis.

```
nuclei -u http://scanme.nmap.org -jsonl -o nuclei-report.json

# Inspect the report:
cat nuclei-report.json | head -60
```

Each line in the output file is a complete JSON object representing one finding. Fields include template-id, type (protocol), severity, host, matched-at (the exact URL or host:port), extracted-results (the evidence pulled from the response), and a timestamp. This format is used when integrating Nuclei into automated security pipelines or SIEM systems.

6.6 Scan 6 — Rate-Limited Scan

This scan demonstrated responsible scanning by limiting the request rate to prevent overloading the target or triggering intrusion detection.

```
nuclei -u http://scanme.nmap.org -rate-limit 50 -severity medium,low
```

The -rate-limit 50 flag capped execution at 50 requests per second, significantly slower than the default aggressive mode. In penetration testing engagements, rate limiting is a professional obligation to avoid causing unintended denial-of-service conditions on the target.

6.7 Complete Findings Summary

The table below consolidates the key findings from the full scan across all protocols:

Template ID	Protocol	Severity	Finding	Target
CVE-2023-48795	JavaScript	MEDIUM	Terrapin Attack — SSH packet injection vulnerability	scanme.nmap.org:22
ssh-weak-algo-supported	JavaScript	MEDIUM	Weak encryption algorithms supported by SSH server	scanme.nmap.org:22
ssh-diffie-hellman-logjam	JavaScript	LOW	Weak Diffie-Hellman key exchange algorithm	scanme.nmap.org:22
ssh-cbc-mode-ciphers	JavaScript	LOW	SSH server supports CBC mode ciphers (weak)	scanme.nmap.org:22
ssh-weak-mac-algo	JavaScript	LOW	Weak MAC algorithms supported by SSH server	scanme.nmap.org:22
ssh-weakkey-exchange-algo	JavaScript	LOW	Weak key exchange algorithms in SSH configuration	scanme.nmap.org:22

apache-mod-negotiation-listing	HTTP	LOW	Apache exposes file listing via mod_negotiation	http://scanme.nmap.org
http-missing-security-headers	HTTP	INFO	11 missing HTTP security headers (CSP, HSTS, X-Frame, etc.)	http://scanme.nmap.org
apache-detect	HTTP	INFO	Apache/2.4.7 on Ubuntu detected (released 2013)	http://scanme.nmap.org
openssh-detect	TCP	INFO	OpenSSH 6.6.1p1 Ubuntu detected	scanme.nmap.org:22
snmpv3-detect	JavaScript	INFO	SNMP v3 service detected on port 161	scanme.nmap.org:161
aaaa-fingerprint	DNS	INFO	IPv6 address resolved (2600:3c01::f03c:91ff:fe18:bb2f)	scanme.nmap.org

7. Analysis of Outcome

7.1 CVE-2023-48795 (Terrapin Attack) — Medium Severity

This is the most significant finding from a security standpoint. CVE-2023-48795, publicly known as the Terrapin Attack, is a vulnerability in the SSH Binary Packet Protocol. It was disclosed in December 2023 and affects the OpenSSH server running on scanme.nmap.org (version 6.6.1p1, released in 2014). The attack allows a network-positioned adversary to perform a prefix truncation attack, manipulating the SSH handshake to downgrade the negotiated connection security. In practice, this can allow an attacker to strip certain SSH protocol extensions and weaken the channel, potentially enabling session hijacking or man-in-the-middle interception. The severity is Medium because exploiting this vulnerability requires a privileged network position (i.e., the attacker must be able to intercept traffic between the client and server).

Remediation: Upgrade OpenSSH to version 9.6 or later, which includes the countermeasures developed in response to this CVE. Disable ChaCha20-Poly1305 and CBC-EtM constructions if immediate patching is not possible.

7.2 Weak SSH Cryptographic Algorithms — Low Severity

Four separate template matches relate to the SSH server's acceptance of deprecated or weak cryptographic primitives. The server supports CBC (Cipher Block Chaining) mode ciphers, which are vulnerable to a variant of the BEAST attack in certain implementations. It also supports weak Diffie-Hellman key exchange groups (susceptible to the Logjam attack), weak MAC (Message Authentication Code) algorithms that use MD5 or 96-bit truncated variants, and generally weak key exchange algorithms. Individually these are Low severity, but collectively they indicate that the SSH service has not been hardened against modern cryptographic best practices. The root cause is the very outdated OpenSSH version — 6.6.1p1 was released in 2014 and has not been updated.

Remediation: Update the SSH server configuration (sshd_config) to explicitly disable weak ciphers, MACs, and key exchange algorithms. Use the Mozilla SSH hardening guidelines as a reference. Upgrading OpenSSH would also resolve most of these issues automatically.

7.3 Missing HTTP Security Headers — Informational

Eleven HTTP response headers that represent security best practices were found to be absent from the web server's responses. The missing headers include Content-Security-Policy (prevents XSS by restricting resource origins), Strict-Transport-Security (forces HTTPS connections), X-Frame-Options (prevents clickjacking), X-Content-Type-Options (prevents MIME-type sniffing), Permissions-Policy (restricts browser features), Cross-Origin-Opener-Policy, Cross-Origin-Embedder-Policy, and Cross-Origin-Resource-Policy. While informational on their own, the absence of these headers in a real production application would significantly increase the risk of successful cross-site scripting and clickjacking attacks.

Remediation: Add the missing security headers to the Apache configuration or via a reverse proxy. Most of these headers can be added in a single directive block in the Apache virtual host configuration file.

7.4 Apache Version Disclosure — Informational

The server is running Apache 2.4.7, which was released in November 2013 — over a decade ago. While this alone is informational, an outdated web server version is a significant indicator of poor patch management hygiene. Attackers routinely use version fingerprinting (as demonstrated by Nuclei's `apache-detect` template) as the first step in identifying which known exploits may be applicable to a target. Version disclosure combined with an outdated version constitutes a meaningful attack surface.

7.5 Observations on Tool Behaviour

Several observations about Nuclei's behaviour are worth noting from this experiment. First, the template clustering mechanism is effective: 9,904 templates were reduced to approximately 7,774 actual requests through deduplication, demonstrating that the engine is designed for efficiency rather than brute-force enumeration. Second, the multi-protocol execution model is genuinely simultaneous — HTTP, SSH, DNS, and SNMP findings all appeared within the same 4-minute scan window. Third, the colour-coded terminal output (green for info, yellow for low, orange for medium) significantly aids rapid visual triage of findings. Fourth, the `-rate-limit` flag is essential for responsible use: without it, the default scan speed could cause issues on production targets.

8. Conclusion

This experiment successfully demonstrated the installation, configuration, and practical use of Nuclei v3.7.1 as a vulnerability assessment tool. Through six distinct scan configurations against the legally scannable `scanme.nmap.org` practice server, the following capabilities were explored and validated: template-based vulnerability detection, multi-protocol scanning across HTTP, SSH, DNS, and SNMP, severity-based and tag-based filtering for targeted analysis, JSON Lines report generation for structured output, and rate-limiting for responsible scanning practice.

The 31 findings produced by the full scan demonstrate that even a single server can present a broad attack surface when viewed through the lens of a comprehensive scanner. The most

significant finding, CVE-2023-48795, represents a real, documented vulnerability that would require urgent remediation in a production environment. The cluster of weak SSH algorithm findings illustrates how outdated software accumulates technical debt that compounds over time.

Nuclei's template-based architecture sets it apart from traditional scanners in several important ways. The ability to inspect, modify, and write templates gives security teams full transparency into detection logic. The community-driven repository means new CVE templates often appear within hours of public disclosure. The CLI-first design makes it suitable for automation in CI/CD pipelines, scheduled infrastructure audits, and large-scale bug bounty reconnaissance.

The tool and all its templates are available as open-source software at: <https://github.com/projectdiscovery/nuclei> and <https://github.com/projectdiscovery/nuclei-templates>. This experiment has provided a strong foundational understanding of automated vulnerability assessment and highlighted the importance of combining tool proficiency with sound knowledge of the underlying security concepts.

References

- ProjectDiscovery. (2024). Nuclei — Fast and customizable vulnerability scanner. GitHub. <https://github.com/projectdiscovery/nuclei>
- ProjectDiscovery. (2024). Nuclei Templates. GitHub. <https://github.com/projectdiscovery/nuclei-templates>
- Bäumer, F., Brinkmann, M., & Schwenk, J. (2023). Terrapin Attack: Breaking SSH Channel Integrity By Sequence Number Manipulation. CVE-2023-48795. <https://terrapin-attack.com>
- National Vulnerability Database. (2023). CVE-2023-48795 Detail. <https://nvd.nist.gov/vuln/detail/CVE-2023-48795>
- Mozilla. (2024). Security/Guidelines/OpenSSH — MozillaWiki. <https://wiki.mozilla.org/Security/Guidelines/OpenSSH>
- OWASP. (2024). OWASP Secure Headers Project. <https://owasp.org/www-project-secure-headers/>